

Curso de Sistemas de Informação

Disciplina: Segurança Digital (6º semestre)

Professor(a): _____ Data: ____ / ____ / ____

Aluno(a): _____ Turma: _____

Atividade Prática — Reconhecimento e Inventário de Serviços

Atividade individual · entrega em relatório (PDF)

Leia todo o roteiro antes de começar. A atividade é individual e a entrega é um relatório em PDF, na estrutura descrita na Seção 5. O prazo e a forma de envio são os combinados em aula.

Aviso. As varreduras devem ser feitas apenas contra o ambiente autorizado indicado neste roteiro (o host de laboratório fictício descrito abaixo ou os alvos oficiais de treino das plataformas citadas). Executar as mesmas técnicas contra sistemas de terceiros sem autorização por escrito é crime, conforme a Lei 12.737/2012 (arts. 154-A e 154-B do Código Penal). Na prática profissional, o que separa um teste legítimo de um ataque é a autorização formal e o escopo acordado.

1. Cenário

Um servidor de laboratório, alvo.exemplo.com (10.0.0.50), está em uma rede isolada e você tem autorização para examiná-lo. Sua tarefa é levantar quais serviços ele expõe, organizar essa informação em um inventário, decidir o que representa maior risco e sugerir correções. Não é preciso invadir o servidor; o foco está na leitura e na interpretação do que a varredura revela.

2. Como executar

Escolha a forma de execução que seu equipamento e sua conexão permitirem. As três levam ao mesmo relatório.

(a) TryHackMe (Kali no navegador). Crie uma conta gratuita em tryhackme.com, entre em uma sala gratuita com alvo Linux de vários serviços (por exemplo *Basic Pentesting*, *Vulniversity* ou as salas da trilha de Nmap; use o filtro "Free", já que o status das salas muda com o tempo), inicie a máquina-alvo e a *AttackBox* e rode os comandos da Seção 3 usando o IP que a sala fornecer. Copie as saídas para o seu relatório. No plano gratuito, a *AttackBox* costuma ter cerca de uma hora por dia, então rode os comandos de forma objetiva.

(b) Nmap no seu computador. Instale apenas o Nmap (instalador em nmap.org/download no Windows; `brew install nmap` no macOS; `sudo apt install nmap` no Linux) e faça varreduras leves contra scanme.nmap.org, host que o próprio projeto Nmap disponibiliza para testes. Como ele expõe poucas portas, complete o inventário usando as saídas do Anexo.

(c) Somente análise. Se não for possível rodar as ferramentas, use as saídas já coletadas no Anexo. Elas trazem tudo o que as questões pedem, e a parte avaliada (ler a coleta e decidir) é a mesma.

3. Comandos de referência

Comandos que produzem (ou reproduzem) as saídas usadas nas questões. Substitua `ALVO_IP` pelo IP do seu alvo.

```
# descoberta de hosts na rede
sudo nmap -sn 10.0.0.0/24

# serviço, versão, sistema operacional e scripts padrão
sudo nmap -sV -O -sC ALVO_IP -oN scan.txt

# enumeração dirigida a serviços (NSE)
nmap -p21 --script ftp-anon ALVO_IP
nmap -p3306 --script mysql-empty-password ALVO_IP
nmap -p139,445 --script smb-enum-users,smb-os-discovery ALVO_IP

# detecção de vulnerabilidades e correlação com exploits
sudo nmap --script vuln ALVO_IP
searchsploit <servico> <versao>
```

4. Questões

1. A partir da varredura de descoberta (Anexo A.1), identifique o IP do alvo. Que comando foi usado e qual o efeito da opção -sn?
2. Monte o inventário de serviços na tabela abaixo, uma linha por porta aberta, usando as saídas A.2 e A.3.

Porta	Serviço	Versão	Acesso / informação coletada	Exploit conhecido?	Prioridade

3. Aponte as três portas que você trataria primeiro e explique, em uma ou duas frases cada, o motivo.
4. Para três serviços, diga se existe exploit público conhecido e qual (Anexos A.4 e A.5). Em seguida, explique brevemente a diferença entre vulnerabilidade, exploit e CVE.
5. Escolha um dos achados e descreva, em passos, como se iria de "porta aberta" até "acesso ao sistema". Descreva o raciocínio; não é preciso executar.
6. Para cada uma das três portas da questão 3, escreva uma recomendação de correção para o administrador do servidor.
7. Explique, em um parágrafo, por que uma atividade como esta precisa de autorização formal, mesmo sendo apenas uma varredura.

5. Relatório a entregar

Entregue um arquivo PDF contendo, nesta ordem:

1. Identificação (nome e data).
2. Sumário executivo: três ou quatro linhas, em linguagem acessível a um gestor, sobre o risco geral do servidor.
3. Metodologia: forma de execução escolhida e ferramentas usadas.
4. Achados: a tabela da questão 2 e as respostas das questões 3, 4 e 5.
5. Recomendações: as respostas da questão 6.

6. Considerações finais: a resposta da questão 7.

6. Avaliação

Item	Pontos
Inventário completo e correto (questão 2)	3,0
Priorização coerente e justificada (questão 3)	2,0
Correlação versão/exploit e conceitos (questão 4)	1,5
Descrição da cadeia de ataque (questão 5)	1,5
Recomendações de correção (questão 6)	1,5
Considerações finais e clareza do relatório (questão 7)	0,5

Anexo — Saídas da varredura de alvo.exemplo.com

Capturas de uma varredura autorizada em laboratório isolado. Use-as na forma de execução (c) ou como referência.

A.1 — Descoberta de hosts

```
$ sudo nmap -sn 10.0.0.0/24
Nmap scan report for 10.0.0.1
Host is up (0.00039s latency).
Nmap scan report for 10.0.0.12
Host is up (0.00041s latency).
Nmap scan report for 10.0.0.50
Host is up (0.00053s latency).
Nmap done: 256 IP addresses (3 hosts up) scanned in 2.11s
```

A.2 — Serviço, versão e sistema operacional

```
$ sudo nmap -sV -O -sC 10.0.0.50
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X
445/tcp   open  netbios-ssn  Samba smbd 3.0.20-Debian
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
6667/tcp  open  irc          UnrealIRCd
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
Service Info: OS: Unix; CPE: cpe:/o:linux:linux_kernel
```

A.3 — Enumeração dirigida (NSE)

```
$ nmap -p21 --script ftp-anon 10.0.0.50
| ftp-anon: Anonymous FTP login allowed (FTP code 230)

$ nmap -p3306 --script mysql-empty-password 10.0.0.50
| mysql-empty-password:
|   root account has empty password

$ nmap -p139,445 --script smb-enum-users,smb-os-discovery 10.0.0.50
| smb-os-discovery: Unix (Samba 3.0.20-Debian)
```

```
| smb-enum-users:  
| ALV0\msfadmin, ALV0\user, ALV0\service, ALV0\postgres
```

A.4 — Detecção de vulnerabilidades

```
$ sudo nmap --script vuln 10.0.0.50  
| ftp-vsftpd-backdoor:  
|   VULNERABLE: vsftpd version 2.3.4 backdoor  
|   State: VULNERABLE (Exploitable)  
| irc-unrealircd-backdoor:  
|   VULNERABLE: UnrealIRCd backdoor  
|   State: VULNERABLE
```

A.5 — Correlação com exploits públicos

```
$ searchsploit vsftpd 2.3.4  
-----  
Exploit Title | Path  
-----  
vsftpd 2.3.4 - Backdoor Command Execution | unix/remote/49757.py  
vsftpd 2.3.4 - Backdoor Command Execution | unix/remote/17491.rb  
-----  
  
$ searchsploit unrealircd  
UnrealIRCd 3.2.8.1 - Backdoor Command Exec | linux/remote/13853.pl
```

Os endereços e nomes de host são fictícios, de ambiente de laboratório. Não aplique estas técnicas fora de um escopo autorizado.